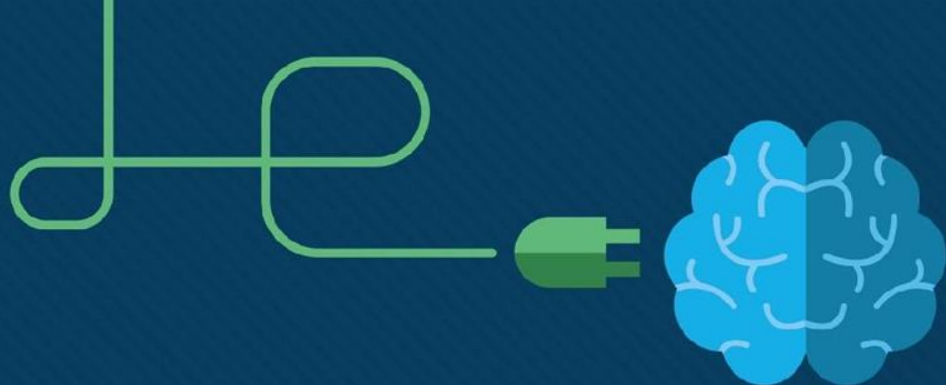




Module 3: Network Security Concepts

Enterprise Networking, Security, and Automation v7.0
(ENSA)



Module Objectives

Module Title: Network Security Concepts

Module Objective: Explain how vulnerabilities, threats, and exploits can be mitigated to enhance network security.

Topic Title	Topic Objective
Current State of Cybersecurity:	Describe the current state of cybersecurity and vectors of data loss.
Threat Actors	Describe tools used by threat actors to exploit networks.
Malware	Describe malware types.
Common Network Attacks	Describe common network attacks.
IP Vulnerabilities and Threats	Explain how IP vulnerabilities are exploited by threat actors.
TCP and UDP Vulnerabilities	Explain how TCP and UDP vulnerabilities are exploited by threat actors.
IP Services	Explain how IP services are exploited by threat actors.
Network Security Best Practices	Describe best practices for protecting a network.
Cryptography	Describe common cryptographic processes used to protect data in transit.

3.1 Current State of Cybersecurity

Current State of Cybersecurity

Current State of Affairs

Cyber criminals now have the expertise and tools necessary to take down critical infrastructure and systems. Their tools and techniques continue to evolve.

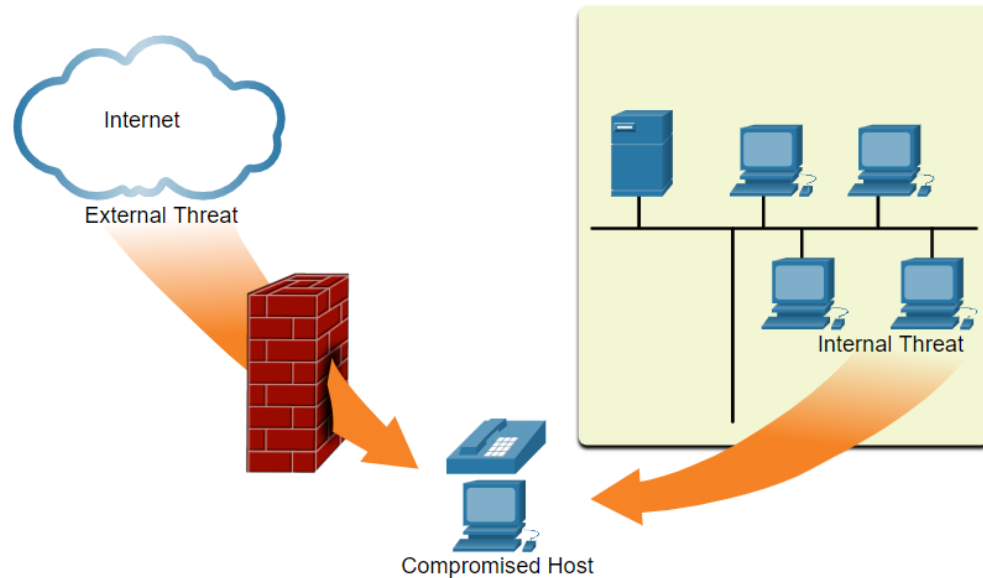
Maintaining a secure network ensures the safety of network users and protects commercial interests. All users should be aware of security terms in the table.

Security Terms	Description
Assets	An asset is anything of value to the organization. It includes people, equipment, resources, and data.
Vulnerability	A vulnerability is a weakness in a system, or its design, that could be exploited by a threat.
Threat	A threat is a potential danger to a company's assets, data, or network functionality.
Exploit	An exploit is a mechanism that takes advantage of a vulnerability.
Mitigation	Mitigation is the counter-measure that reduces the likelihood or severity of a potential threat or risk. Network security involves multiple mitigation techniques.
Risk	Risk is the likelihood of a threat to exploit the vulnerability of an asset, with the aim of negatively affecting an organization. Risk is measured using the probability of the occurrence of an event and its consequences.

Current State of Cybersecurity

Vectors of Network Attacks

An attack vector is a path by which a threat actor can gain access to a server, host, or network. Attack vectors originate from inside or outside the corporate network, as shown in the figure. Internal threats have the potential to cause greater damage than external threats because internal users have direct access to the building and its infrastructure devices.



Current State of Cybersecurity

Data Loss

Data loss or data exfiltration is when data is intentionally or unintentionally lost, stolen, or leaked to the outside world. The data loss can result in:

- Brand damage and loss of reputation

- Loss of competitive advantage

- Loss of customers

- Loss of revenue

- Litigation/legal action resulting in fines and civil penalties

- Significant cost and effort to notify affected parties and recover from the breach

Network security professionals must protect the organization's data. Various Data Loss Prevention (DLP) controls must be implemented which combine strategic, operational and tactical measures.

Current State of Cybersecurity

Data Loss (Cont.)

Data Loss Vectors	Description
Email/Social Networking	Intercepted email or IM messages could be captured and reveal confidential information.
Unencrypted Devices	If the data is not stored using an encryption algorithm, then the thief can retrieve valuable confidential data.
Cloud Storage Devices	Sensitive data can be lost if access to the cloud is compromised due to weak security settings.
Removable Media	One risk is that an employee could perform an unauthorized transfer of data to a USB drive. Another risk is that a USB drive containing valuable corporate data could be lost.
Hard Copy	Confidential data should be shredded when no longer required.
Improper Access Control	Passwords or weak passwords which have been compromised can provide a threat actor with easy access to corporate data.

3.2 Threat Actors

Threat Actors

The Hacker

Hacker is a common term used to describe a threat actor

Hacker Type	Description
White Hat Hackers	These are ethical hackers who use their programming skills for good, ethical, and legal purposes. Security vulnerabilities are reported to developers for them to fix before the vulnerabilities can be exploited.
Gray Hat Hackers	These are individuals who commit crimes and do arguably unethical things, but not for personal gain or to cause damage. Gray hat hackers may disclose a vulnerability to the affected organization after having compromised their network.
Black Hat Hackers	These are unethical criminals who compromise computer and network security for personal gain, or for malicious reasons, such as attacking networks.

The Evolution of Hackers

The table displays modern hacking terms and a brief description of each.

Hacking Term	Description
Script Kiddies	These are teenagers or inexperienced hackers running existing scripts, tools, and exploits, to cause harm, but typically not for profit.
Vulnerability Broker	These are usually gray hat hackers who attempt to discover exploits and report them to vendors, sometimes for prizes or rewards.
Hacktivists	These are gray hat hackers who publicly protest organizations or governments by posting articles, videos, leaking sensitive information, and performing network attacks.
Cyber criminals	These are black hat hackers who are either self-employed or working for large cybercrime organizations.
State-Sponsored	These are either white hat or black hat hackers who steal government secrets, gather intelligence, and sabotage networks. Their targets are foreign governments, terrorist groups, and corporations. Most countries in the world participate to some degree in state-sponsored hacking

3.3 Threat Actor Tools

Video – Threat Actor Tools

This video will cover the following:

- Explain the penetration testing tools

- Explain attack types

Introduction to Attack Tools

To exploit a vulnerability, a threat actor must have a technique or tool. Over the years, attack tools have become more sophisticated, and highly automated. These new tools require less technical knowledge to implement.

Threat Actor Tools

Evolution of Security Tools

The table highlights categories of common penetration testing tools. Notice how some tools are used by white hats and black hats. Keep in mind that the list is not exhaustive as new tools are always being developed.

Penetration Testing Tool	Description
Password Crackers	Password cracking tools are often referred to as password recovery tools and can be used to crack or recover a password. Password crackers repeatedly make guesses in order to crack the password. Examples of password cracking tools include John the Ripper, Ophcrack, L0phtCrack, THC Hydra, Rainbow Crack, and Medusa.
Wireless Hacking Tools	Wireless hacking tools are used to intentionally hack into a wireless network to detect security vulnerabilities. Examples of wireless hacking tools include Aircrack-ng, Kismet, InSSIDer, KisMAC, Firesheep, and WiStumbler.
Network Scanning and Hacking Tools	Network scanning tools are used to probe network devices, servers, and hosts for open TCP or UDP ports. Examples of scanning tools include Nmap, SuperScan, Angry IP Scanner, and NetScanTools.
Packet Crafting Tools	These tools are used to probe and test a firewall's robustness using specially crafted forged packets. Examples include Hping, Scapy, Socat, Yersinia, Netcat, Nping, and Nemesis.
Packet Sniffers	These tools are used to capture and analyze packets within traditional Ethernet LANs or WLANs. Tools include Wireshark, Tcpdump, Ettercap, Dsniff, EtherApe, Paros, Fiddler, Ratproxy, and SSLstrip.

Threat Actor Tools

Evolution of Security Tools (Cont.)

Penetration Testing Tool	Description
Rootkit Detectors	This is a directory and file integrity checker used by white hats to detect installed root kits. Example tools include AIDE, Netfilter, and PF: OpenBSD Packet Filter.
Fuzzers to Search Vulnerabilities	Fuzzers are tools used by threat actors to discover a computer's security vulnerabilities. Examples of fuzzers include Skipfish, Wapiti, and W3af.
Forensic Tools	These tools are used by white hat hackers to sniff out any trace of evidence existing in a computer. Example of tools include Sleuth Kit, Helix, Maltego, and Encase.
Debuggers	These tools are used by black hats to reverse engineer binary files when writing exploits. They are also used by white hats when analyzing malware. Debugging tools include GDB, WinDbg, IDA Pro, and Immunity Debugger.
Hacking Operating Systems	These are specially designed operating systems preloaded with tools optimized for hacking. Examples of specially designed hacking operating systems include Kali Linux, BackBox Linux.
Encryption Tools	Encryption tools use algorithm schemes to encode the data to prevent unauthorized access to the encrypted data. Examples of these tools include VeraCrypt, CipherShed, OpenSSH, OpenSSL, Tor, OpenVPN, and Stunnel.
Vulnerability Exploitation Tools	These tools identify whether a remote host is vulnerable to a security attack. Examples of vulnerability exploitation tools include Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit, and Netsparker.
Vulnerability Scanners	These tools scan a network or system to identify open ports. They can also be used to scan for known vulnerabilities and scan VMs, BYOD devices, and client databases. Examples of tools include Nipper, Core Impact, Nessus, SAINT, and OpenVAS

Threat Actor Tools

Attack Types

Attack Type	Description
Eavesdropping Attack	This is when a threat actor captures and “listens” to network traffic. This attack is also referred to as sniffing or snooping.
Data Modification Attack	If threat actors have captured enterprise traffic, they can alter the data in the packet without the knowledge of the sender or receiver.
IP Address Spoofing Attack	A threat actor constructs an IP packet that appears to originate from a valid address inside the corporate intranet.
Password-Based Attacks	If threat actors discover a valid user account, the threat actors have the same rights as the real user. Threat actors could use that valid account to obtain lists of other users, network information, change server and network configurations, and modify, reroute, or delete data.
Denial of Service Attack	A DoS attack prevents normal use of a computer or network by valid users. A DoS attack can flood a computer or the entire network with traffic until a shutdown occurs because of the overload. A DoS attack can also block traffic, which results in a loss of access to network resources by authorized users.
Man-in-the-Middle Attack	This attack occurs when threat actors have positioned themselves between a source and destination. They can now actively monitor, capture, and control the communication transparently.
Compromised-Key Attack	If a threat actor obtains a secret key, that key is referred to as a compromised key. A compromised key can be used to gain access to a secured communication without the sender or receiver being aware of the attack.
Sniffer Attack	A sniffer is an application or device that can read, monitor, and capture network data exchanges and read network packets. If the packets are not encrypted, a sniffer provides a full view of the data inside the packet

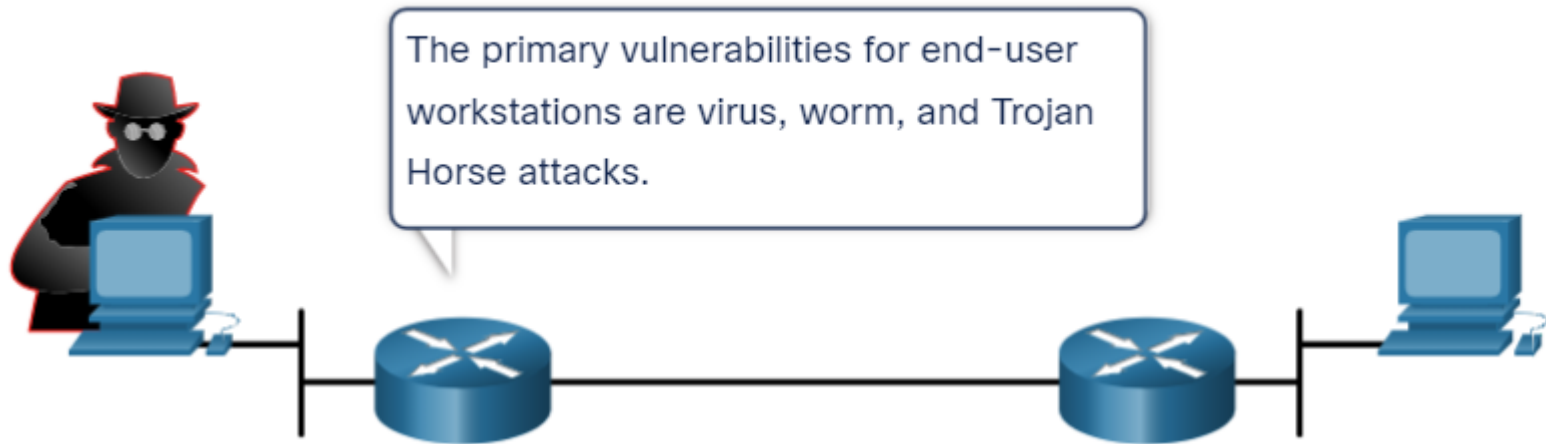
3.4 Malware

Malware

Overview of Malware

Now that you know about the tools that hacker use, this topic introduces you to different types of malware that hackers use to gain access to end devices.

End devices are particularly prone to malware attacks. It is important to know about malware because threat actors rely on users to install malware to help exploit the security gaps.



Malware

Viruses and Trojan Horses

The first and most common type of computer malware is a virus. Viruses require human action to propagate and infect other computers.

The virus hides by attaching itself to computer code, software, or documents on the computer. When opened, the virus executes and infects the computer.

Viruses can:

- Alter, corrupt, delete files, or erase entire drives.
- Cause computer booting issues, and corrupt applications.
- Capture and send sensitive information to threat actors.
- Access and use email accounts to spread.
- Lay dormant until summoned by the threat actor.

Malware

Viruses and Trojan Horses (Cont.)

Modern viruses are developed for specific intent such as those listed in the table.

Types of Viruses	Description
Boot sector virus	Virus attacks the boot sector, file partition table, or file system.
Firmware viruses	Virus attacks the device firmware.
Macro virus	Virus uses the MS Office macro feature maliciously.
Program viruses	Virus inserts itself in another executable program.
Script viruses	Virus attacks the OS interpreter which is used to execute scripts.

Malware

Viruses and Trojan Horses (Cont.)

Threat actors use Trojan horses to compromise hosts. A Trojan horse is a program that looks useful but also carries malicious code. Trojan horses are often provided with free online programs such as computer games. There are several types of Trojan horses as described in the table.

Type of Trojan Horse	Description
Remote-access	Trojan horse enables unauthorized remote access.
Data-sending	Trojan horse provides the threat actor with sensitive data, such as passwords.
Destructive	Trojan horse corrupts or deletes files.
Proxy	Trojan horse will use the victim's computer as the source device to launch attacks and perform other illegal activities.
FTP	Trojan horse enables unauthorized file transfer services on end devices.
Security software disabler	Trojan horse stops antivirus programs or firewalls from functioning.
Denial of Service (DoS)	Trojan horse slows or halts network activity.
Keylogger	Trojan horse actively attempts to steal confidential information, such as credit card numbers, by recording key strokes entered into a web form.

Malware

Other Types of Malware

Malware	Description
Adware	•Adware is usually distributed by downloading online software. •Adware can display unsolicited advertising using pop-up web browser windows, new toolbars, or unexpectedly redirect a webpage to a different website. •Pop-up windows may be difficult to control as new windows can pop-up faster than the user can close them.
Ransomware	•Ransomware typically denies a user access to their files by encrypting the files and then displaying a message demanding a ransom for the decryption key. •Users without up-to-date backups must pay the ransom to decrypt their files. •Payment is usually made using wire transfer or crypto currencies such as Bitcoin.
Rootkit	•Rootkits are used by threat actors to gain administrator account-level access to a computer. •They are very difficult to detect because they can alter firewall, antivirus protection, system files, and even OS commands to conceal their presence. •They can provide a backdoor to threat actors giving them access to the PC, and allowing them to upload files, and install new software to be used in a DDoS attack. •Special rootkit removal tools must be used to remove them, or a complete OS re-install may be required.
Spyware	•Like adware but, used to gather information about the user and send to threat actors without the user's consent. •Spyware can be a low threat, gathering browsing data, or it can be a high threat capturing personal and financial information.
Worm	•A worm is a self-replicating program that propagates automatically without user actions by exploiting vulnerabilities in legitimate software. •It uses the network to search for other victims with the same vulnerability. •The intent of a worm is usually to slow or disrupt network operations

3.5 Common Network Attacks

Overview of Common Network Attacks

When malware is delivered and installed, the payload can be used to cause a variety of network related attacks.

To mitigate attacks, it is useful to understand the types of attacks. By categorizing network attacks, it is possible to address types of attacks rather than individual attacks.

Networks are susceptible to the following types of attacks:

- Reconnaissance Attacks
- Access Attacks
- DoS Attacks

Video - Common Network Attacks

This video will explain the following techniques used in a reconnaissance attack:

- Perform an information query on a target

- Initiate a ping sweep of the target network

- Initiate a port scan of active ip addresses

- Run vulnerability scanners

- Run exploitation tools

Reconnaissance Attacks

Reconnaissance is information gathering.

Threat actors use reconnaissance (or recon) attacks to do unauthorized discovery and mapping of systems, services, or vulnerabilities. Recon attacks precede access attacks or DoS attacks.

Common Network Attacks

Reconnaissance Attacks (Cont.)

Some of the techniques used by malicious threat actors to conduct reconnaissance attacks are described in the table.

Technique	Description
Perform an information query of a target	The threat actor is looking for initial information about a target. Various tools can be used, including the Google search, organizations website, whois, and more.
Initiate a ping sweep of the target network	The information query usually reveals the target's network address. The threat actor can now initiate a ping sweep to determine which IP addresses are active.
Initiate a port scan of active IP addresses	This is used to determine which ports or services are available. Examples of port scanners include Nmap, SuperScan, Angry IP Scanner, and NetScanTools.
Run vulnerability scanners	This is to query the identified ports to determine the type and version of the application and operating system that is running on the host. Examples of tools include Nipper, Core Impact, Nessus, SAINT, and Open VAS.
Run exploitation tools	The threat actor now attempts to discover vulnerable services that can be exploited. A variety of vulnerability exploitation tools exist including Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit, and Netsparker.

Video – Access and Social Engineering Attacks

This video will cover the following:

Techniques used in **access attacks** (password attacks, spoofing attacks, trust exploitations, port redirections, man-in-the-middle attacks, buffer overflow attacks)

Techniques used in **social engineering attacks** (pretesting, phishing, spear phishing, spam, something for something, baiting, impersonation, tailgating, shoulder surfing, dumpster diving)

Common Network Attacks

Access Attacks

Access attacks exploit known vulnerabilities in authentication services, FTP services, and web services. The purpose of these types of attacks is to gain entry to web accounts, confidential databases, and other sensitive information.

Threat actors use access attacks on network devices and computers to retrieve data, gain access, or to escalate access privileges to administrator status.

Password Attacks: In a password attack, the threat actor attempts to discover critical system passwords using various methods. Password attacks are very common and can be launched using a variety of password cracking tools.

Spoofing Attacks: In spoofing attacks, the threat actor device attempts to pose as another device by falsifying data. Common spoofing attacks include IP spoofing, MAC spoofing, and DHCP spoofing. These spoofing attacks will be discussed in more detail later in this module

Other Access attacks include:

- Trust exploitations
- Port redirections
- Man-in-the-middle attacks
- Buffer overflow attacks

Social Engineering Attacks

Social engineering is an access attack that attempts to manipulate individuals into performing actions or divulging confidential information. Some social engineering techniques are performed in-person while others may use the telephone or internet. Social engineers often rely on people's willingness to be helpful. They also prey on people's weaknesses.

Common Network Attacks

Social Engineering Attacks (Cont.)

Social Engineering Attack	Description
Pretexting	A threat actor pretends to need personal or financial data to confirm the identity of the recipient.
Phishing	A threat actor sends fraudulent email which is disguised as being from a legitimate, trusted source to trick the recipient into installing malware on their device, or to share personal or financial information.
Spear phishing	A threat actor creates a targeted phishing attack tailored for a specific individual or organization.
Spam	Also known as junk mail, this is unsolicited email which often contains harmful links, malware, or deceptive content.
Something for Something	Sometimes called “Quid pro quo”, this is when a threat actor requests personal information from a party in exchange for something such as a gift.
Baiting	A threat actor leaves a malware infected flash drive in a public location. A victim finds the drive and unsuspectingly inserts it into their laptop, unintentionally installing malware.
Impersonation	This type of attack is where a threat actor pretends to be someone they are not to gain the trust of a victim.
Tailgating	This is where a threat actor quickly follows an authorized person into a secure location to gain access to a secure area.
Shoulder surfing	This is where a threat actor inconspicuously looks over someone’s shoulder to steal their passwords or other information.
Dumpster diving	This is where a threat actor rummages through trash bins to discover confidential documents

Common Network Attacks

Social Engineering Attacks (Cont.)

The Social Engineering Toolkit (SET) was designed to help white hat hackers and other network security professionals create social engineering attacks to test their own networks.

Enterprises must educate their users about the risks of social engineering, and develop strategies to validate identities over the phone, via email, or in person.

The figure shows recommended practices that should be followed by all users.



Common Network Attacks

Lab - Social Engineering

In this lab, you will research examples of social engineering and identify ways to recognize and prevent it.

Video – Denial of Service Attacks

This video will cover the following:

- Techniques used in Denial-of-Service attacks (overwhelming quantity of traffic, maliciously formatted packets)

- Techniques used in Distributed Denial of Service attacks (zombies)

DoS and DDoS Attacks

A Denial of Service (DoS) attack creates some sort of interruption of network services to users, devices, or applications. There are two major types of DoS attacks:

- **Overwhelming Quantity of Traffic** - The threat actor sends an enormous quantity of data at a rate that the network, host, or application cannot handle. This causes transmission and response times to slow down. It can also crash a device or service.
- **Maliciously Formatted Packets** - The threat actor sends a maliciously formatted packet to a host or application and the receiver is unable to handle it. This causes the receiving device to run very slowly or crash.

DoS attacks are a major risk because they interrupt communication and cause significant loss of time and money. These attacks are relatively simple to conduct, even by an unskilled threat actor.

A Distributed DoS Attack (DDoS) is similar to a DoS attack, but it originates from multiple, coordinated sources.

3.6 IP Vulnerabilities and Threats

Video – Common IP and ICMP Attacks

This video will cover the following:

Techniques used in IP attacks (ICMP attacks, amplification and reflection attacks, address spoofing attacks, man-in-the-middle attacks, session hijacking)

Techniques used in ICMP attacks (ICMP echo request and echo reply, ICMP unreachable, ICMP mask reply, ICMP redirects, ICMP router discovery)

IP Vulnerabilities and Threats

IPv4 and IPv6

IP does not validate whether the source IP address contained in a packet actually came from that source. For this reason, threat actors can send packets using a spoofed source IP address. Security analysts must understand the different fields in both the IPv4 and IPv6 headers.

Some of the more common IP related attacks are shown in the table

IP Attack Techniques	Description
ICMP attacks	Threat actors use Internet Control Message Protocol (ICMP) echo packets (pings) to discover subnets and hosts on a protected network, to generate DoS flood attacks, and to alter host routing tables.
Amplification and reflection attacks	Threat actors attempt to prevent legitimate users from accessing information or services using DoS and DDoS attacks.
Address spoofing attacks	Threat actors spoof the source IP address in an IP packet to perform blind spoofing or non-blind spoofing.
Man-in-the-middle attack (MITM)	Threat actors position themselves between a source and destination to transparently monitor, capture, and control the communication. They could eavesdrop by inspecting captured packets, or alter packets and forward them to their original destination.
Session hijacking	Threat actors gain access to the physical network, and then use an MITM attack to hijack a session

IP Vulnerabilities and Threats

ICMP Attacks

Threat actors use ICMP for reconnaissance and scanning attacks. They can launch information-gathering attacks to map out a network topology, discover which hosts are active (reachable), identify the host operating system (OS fingerprinting), and determine the state of a firewall. Threat actors also use **ICMP for DoS attacks**.

Note: ICMP for IPv4 (ICMPv4) and ICMP for IPv6 (ICMPv6) are susceptible to similar types of attacks.

Networks should have strict ICMP access control list (ACL) filtering on the network edge to avoid ICMP probing from the internet. In the case of large networks, security devices such as firewalls and intrusion detection systems (IDS) detect such attacks and generate alerts to the security analysts.

IP Vulnerabilities and Threats

ICMP Attacks (Cont.)

Common ICMP messages of interest to threat actors are listed in the table.

ICMP Messages used by Hackers	Description
ICMP echo request and echo reply	This is used to perform host verification and DoS attacks.
ICMP unreachable	This is used to perform network reconnaissance and scanning attacks.
ICMP mask reply	This is used to map an internal IP network.
ICMP redirects	This is used to lure a target host into sending all traffic through a compromised device and create a MITM attack.
ICMP router discovery	This is used to inject bogus route entries into the routing table of a target host.

Video – Amplification, Reflection, and Spoofing Attacks

This video will explain the amplification, reflection, and spoofing attack.

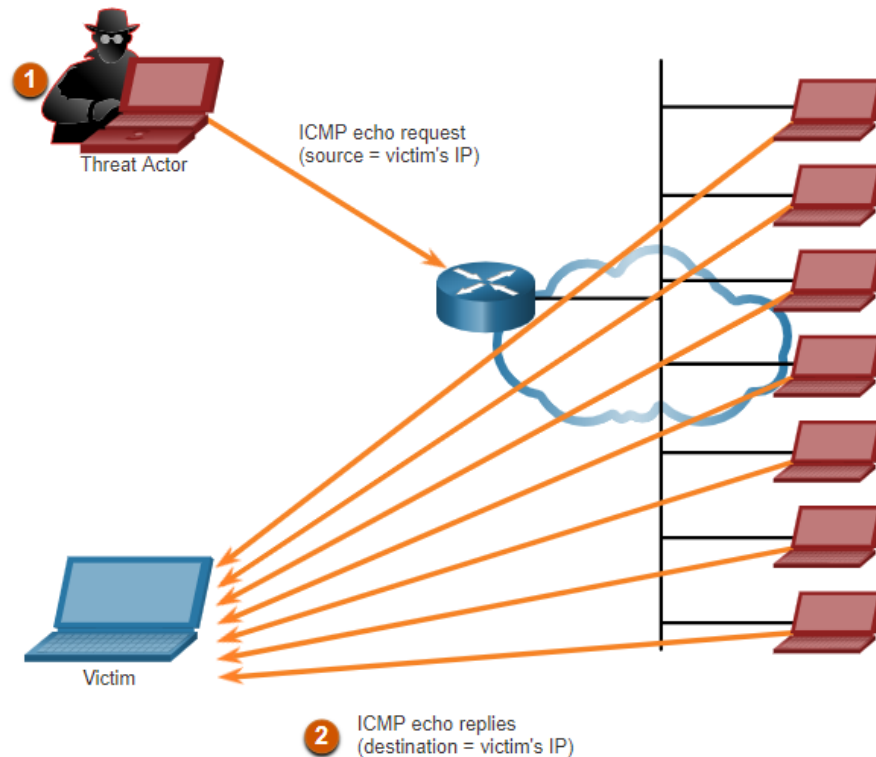
IP Vulnerabilities and Threats

Amplification and Reflection Attacks

Threat actors often use amplification and reflection techniques to create DoS attacks. The example in the figure illustrates a **Smurf attack** is used to overwhelm a target host.

- **Note:** Newer forms of amplification and reflection attacks such as DNS-based reflection and amplification attacks and Network Time Protocol (NTP) amplification attacks are now being used.

Threat actors also use resource exhaustion attacks to either to crash a target host or to consume the resources of a network.



IP Vulnerabilities and Threats

Address Spoofing Attacks

IP address spoofing attacks occur when a threat actor creates packets with false source IP address information to either hide the identity of the sender, or to pose as another legitimate user. Spoofing is usually incorporated into another attack such as a Smurf attack.

Spoofing attacks can be non-blind or blind:

- **Non-blind spoofing** - The threat actor can see the traffic that is being sent between the host and the target. Non-blind spoofing determines the state of a firewall and sequence-number prediction. It can also hijack an authorized session.
- **Blind spoofing** - The threat actor cannot see the traffic that is being sent between the host and the target. Blind spoofing is used in DoS attacks.

MAC address spoofing attacks are used when threat actors have access to the internal network. Threat actors alter the MAC address of their host to match another known MAC address of a target host.

3.7 TCP and UDP Vulnerabilities

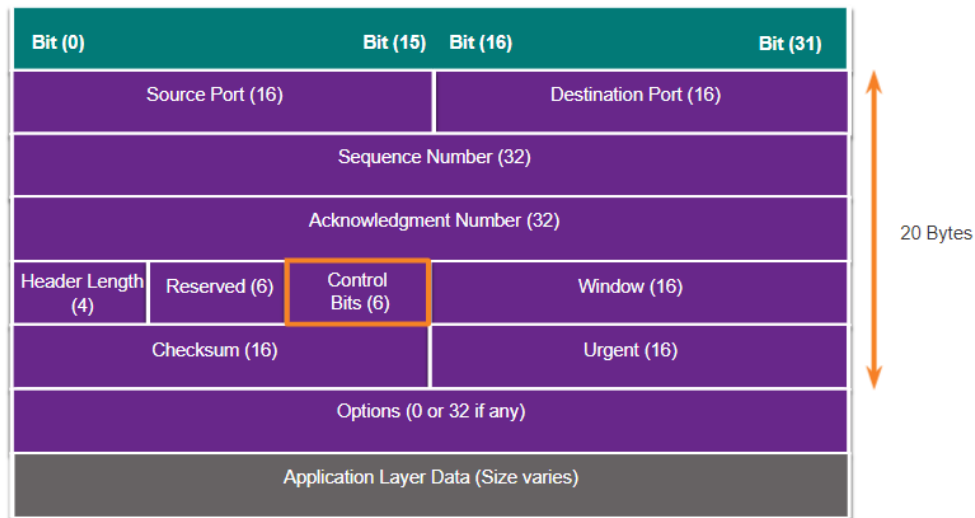
TCP and UDP Vulnerabilities

TCP Segment Header

TCP segment information appears immediately after the IP header. The fields of the TCP segment and the flags for the Control Bits field are displayed in the figure.

The following are the six control bits of the TCP segment:

- **URG** - Urgent pointer field significant
- **ACK** - Acknowledgment field significant
- **PSH** - Push function
- **RST** - Reset the connection
- **SYN** - Synchronize sequence numbers
- **FIN** - No more data from sender



TCP and UDP Vulnerabilities

TCP Services

TCP provides these services:

Reliable delivery - TCP incorporates acknowledgments to guarantee delivery. If a timely acknowledgment is not received, the sender retransmits the data. Requiring acknowledgments of received data can cause substantial delays. Examples of application layer protocols that make use of TCP reliability include HTTP, SSL/TLS, FTP, DNS zone transfers, and others.

Flow control - TCP implements flow control to address this issue. Rather than acknowledge one segment at a time, multiple segments can be acknowledged with a single acknowledgment segment.

Stateful communication - TCP stateful communication between two parties occurs during the TCP three-way handshake.

TCP and UDP Vulnerabilities

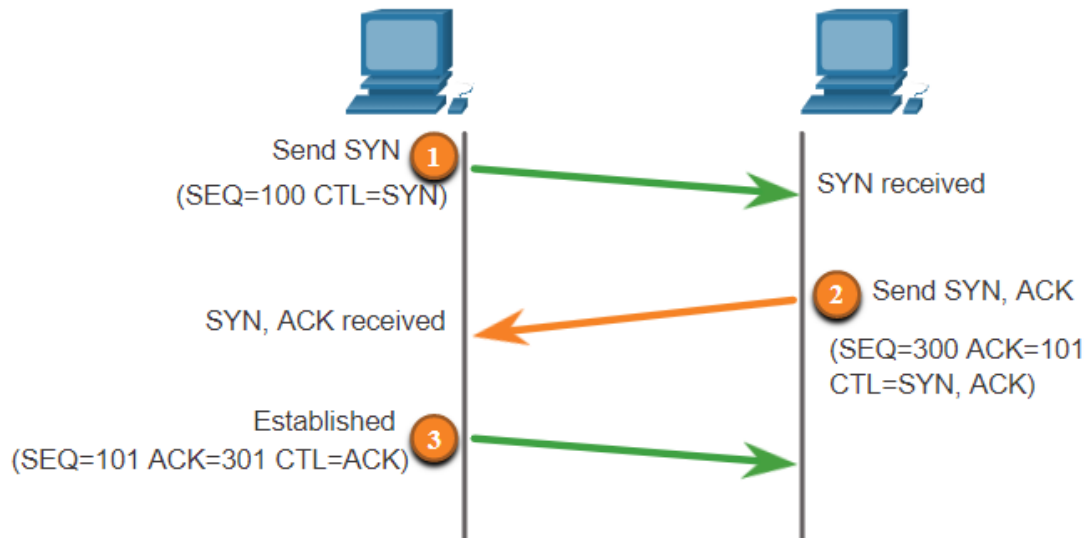
TCP Services (Cont.)

A TCP connection is established in three steps:

The initiating client requests a client-to-server communication session with the server.

The server acknowledges the client-to-server communication session and requests a server-to-client communication session.

The initiating client acknowledges the server-to-client communication session.



TCP and UDP Vulnerabilities

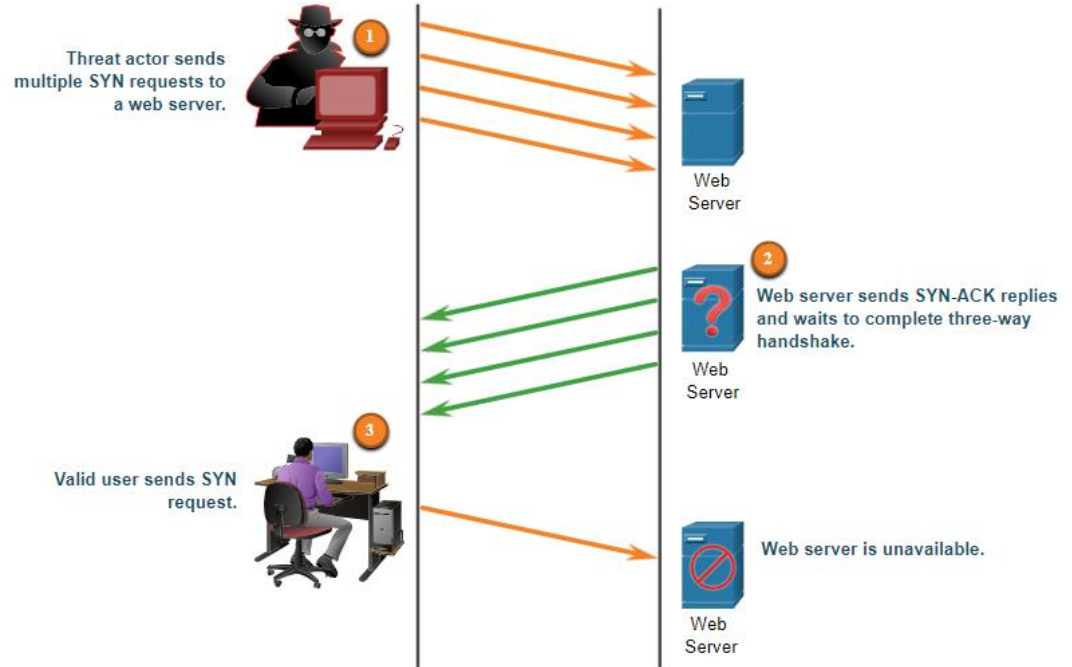
TCP Attacks

TCP SYN Flood Attack

The threat actor sends multiple SYN requests to a webserver.

The web server replies with SYN-ACKs for each SYN request and waits to complete the three-way handshake. The threat actor does not respond to the SYN-ACKs.

A valid user cannot access the web server because the web server has too many half-opened TCP connections.



TCP and UDP Vulnerabilities

TCP Attacks (Cont.)

Terminating a TCP session uses the following four-way exchange process:

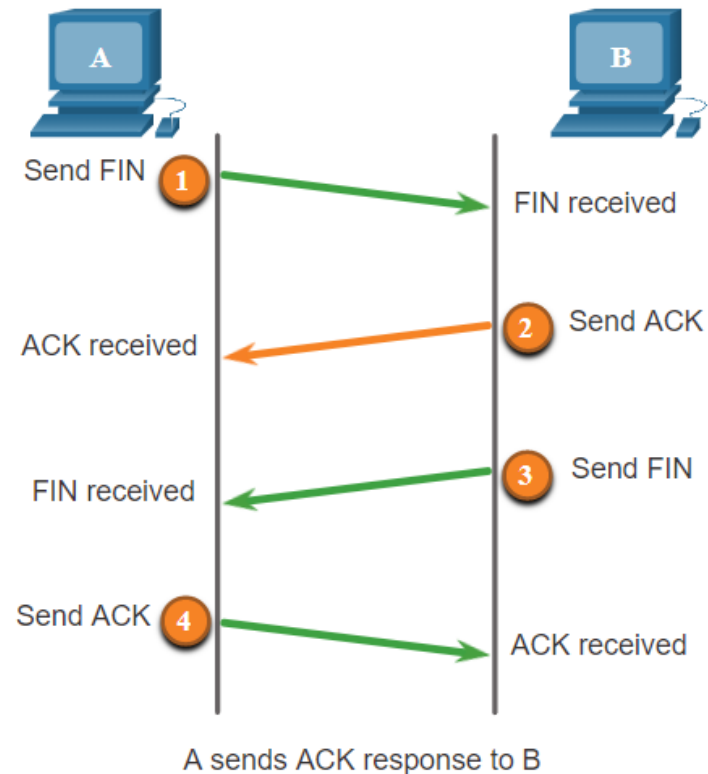
When the client has no more data to send in the stream, it sends a segment with the FIN flag set.

The server sends an ACK to acknowledge the receipt of the FIN to terminate the session from client to server.

The server sends a FIN to the client to terminate the server-to-client session.

The client responds with an ACK to acknowledge the FIN from the server.

A threat actor could do a TCP reset attack and send a spoofed packet containing a TCP RST to one or both endpoints.



TCP and UDP Vulnerabilities

TCP Attacks (Cont.)

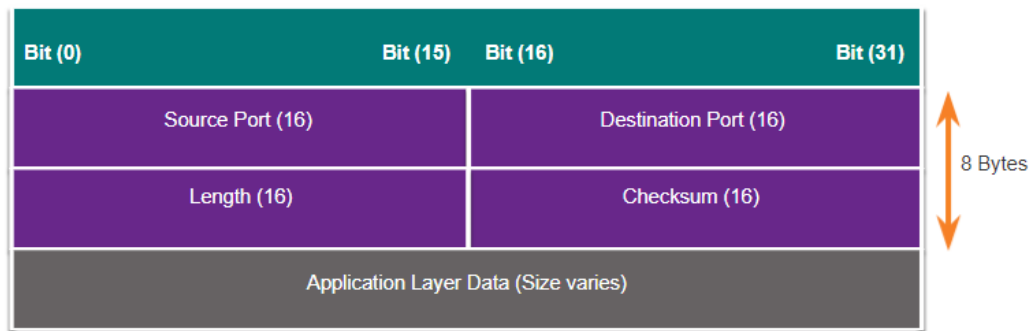
TCP session hijacking is another TCP vulnerability. Although difficult to conduct, a threat actor takes over an already-authenticated host as it communicates with the target. The threat actor must spoof the IP address of one host, predict the next sequence number, and send an ACK to the other host. If successful, the threat actor could send, but not receive, data from the target device.

UDP Segment Header and Operation

UDP is commonly used by DNS, TFTP, NFS, and SNMP. It is also used with real-time applications such as media streaming or VoIP. UDP is a connectionless transport layer protocol. It has much lower overhead than TCP because it is not connection-oriented and does not offer the sophisticated retransmission, sequencing, and flow control mechanisms that provide reliability.

These reliability functions are not provided by the transport layer protocol and must be implemented elsewhere if required.

The low overhead of UDP makes it very desirable for protocols that make simple request and reply transactions.



TCP and UDP Vulnerabilities

UDP Attacks

UDP is not protected by any encryption. You can add encryption to UDP, but it is not available by default. The lack of encryption means that anyone can see the traffic, change it, and send it on to its destination.

UDP Flood Attacks: The threat actor uses a tool like UDP Unicorn or Low Orbit Ion Cannon. These tools send a flood of UDP packets, often from a spoofed host, to a server on the subnet. The program will sweep through all the known ports trying to find closed ports. This will cause the server to reply with an ICMP port unreachable message. Because there are many closed ports on the server, this creates a lot of traffic on the segment, which uses up most of the bandwidth. The result is very similar to a DoS attack.

3.8 IP Services

IP Services

ARP Vulnerabilities

Hosts broadcast an ARP Request to other hosts on the segment to determine the MAC address of a host with a particular IP address. The host with the matching IP address in the ARP Request sends an ARP Reply.

Any client can send an unsolicited ARP Reply called a “gratuitous ARP.” When a host sends a gratuitous ARP, other hosts on the subnet store the MAC address and IP address contained in the gratuitous ARP in their ARP tables.

This feature of ARP also means that any host can claim to be the owner of any IP or MAC. A threat actor can poison the ARP cache of devices on the local network, creating an MITM attack to redirect traffic.

ARP cache poisoning can be used to launch various man-in-the-middle attacks.

PC-A requires the MAC address of its default gateway (R1); therefore, it sends an ARP Request for the MAC address of 192.168.10.1.

R1 updates its ARP cache with the IP and MAC addresses of PC-A. R1 sends an ARP Reply to PC-A, which then updates its ARP cache with the IP and MAC addresses of R1.

The threat actor sends two spoofed gratuitous ARP Replies using its own MAC address for the indicated destination IP addresses. PC-A updates its ARP cache with its default gateway which is now pointing to the threat actor's host MAC address. R1 also updates its ARP cache with the IP address of PC-A pointing to the threat actor's MAC address.

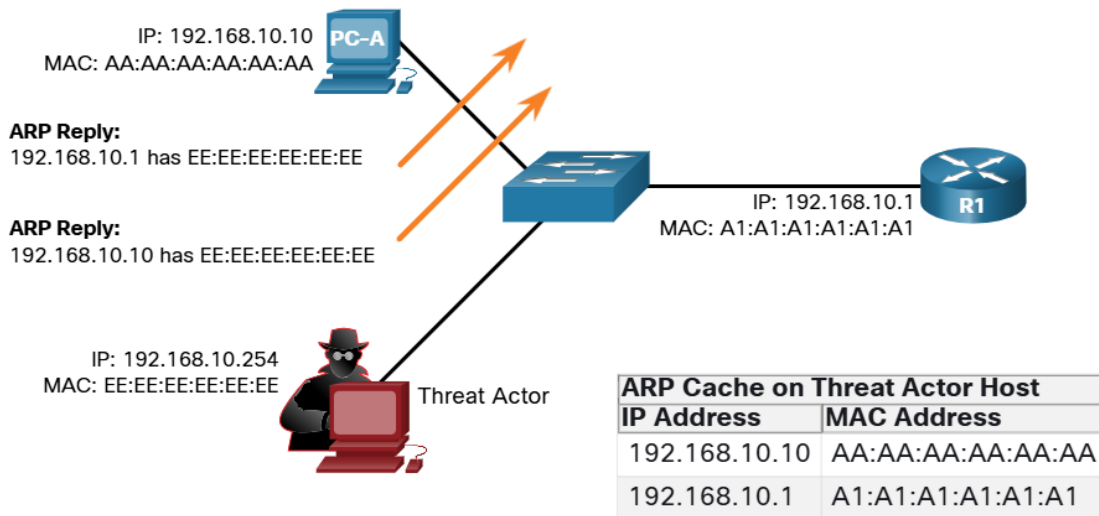
The ARP poisoning attack can be passive or active. Passive ARP poisoning is where threat actors steal confidential information. Active ARP poisoning is where threat actors modify data in transit or inject malicious data.

IP Services

ARP Cache Poisoning

ARP Cache on PC-A	
IP Address	MAC Address
192.168.10.1	EE:EE:EE:EE:EE:EE

ARP Cache on R1	
IP Address	MAC Address
192.168.10.10	EE:EE:EE:EE:EE:EE



Video – ARP Spoofing

This video will explain an ARP spoofing attack.

IP Services

DNS Attacks

The Domain Name Service (DNS) protocol defines an automated service that matches resource names, such as `www.cisco.com`, with the required numeric network address, such as the IPv4 or IPv6 address. It includes the format for queries, responses, and data and uses resource records (RR) to identify the type of DNS response.

Securing DNS is often overlooked. However, it is crucial to the operation of a network and should be secured accordingly.

DNS attacks include the following:

- DNS open resolver attacks
- DNS stealth attacks
- DNS domain shadowing attacks
- DNS tunneling attacks

DNS Attacks (Cont.)

DNS Open Resolver Attacks: A DNS open resolver answers queries from clients outside of its administrative domain. DNS open resolvers are vulnerable to multiple malicious activities described in the table.

DNS Resolver Vulnerabilities	Description
DNS cache poisoning attacks	Threat actors send spoofed, falsified record resource (RR) information to a DNS resolver to redirect users from legitimate sites to malicious sites. DNS cache poisoning attacks can all be used to inform the DNS resolver to use a malicious name server that is providing RR information for malicious activities.
DNS amplification and reflection attacks	Threat actors use DoS or DDoS attacks on DNS open resolvers to increase the volume of attacks and to hide the true source of an attack. Threat actors send DNS messages to the open resolvers using the IP address of a target host. These attacks are possible because the open resolver will respond to queries from anyone asking a question.
DNS resource utilization attacks	A DoS attack that consumes the resources of the DNS open resolvers. This DoS attack consumes all the available resources to negatively affect the operations of the DNS open resolver. The impact of this DoS attack may require the DNS open resolver to be rebooted or services to be stopped and restarted.

DNS Attacks (Cont.)

DNS Stealth Attacks: To hide their identity, threat actors also use the DNS stealth techniques described in the table to carry out their attacks.

DNS Stealth Techniques	Description
Fast Flux	Threat actors use this technique to hide their phishing and malware delivery sites behind a quickly-changing network of compromised DNS hosts. The DNS IP addresses are continuously changed within minutes. Botnets often employ Fast Flux techniques to effectively hide malicious servers from being detected.
Double IP Flux	Threat actors use this technique to rapidly change the hostname to IP address mappings and to also change the authoritative name server. This increases the difficulty of identifying the source of the attack.
Domain Generation Algorithms	Threat actors use this technique in malware to randomly generate domain names that can then be used as rendezvous points to their command and control (C&C) servers.

DNS Attacks (Cont.)

DNS Domain Shadowing Attacks: Domain shadowing involves the threat actor gathering domain account credentials in order to silently create multiple sub-domains to be used during the attacks. These subdomains typically point to malicious servers without alerting the actual owner of the parent domain.

IP Services

DNS Tunneling

Threat actors who use DNS tunneling place non-DNS traffic within DNS traffic. This method often circumvents security solutions when a threat actor wishes to communicate with bots inside a protected network, or exfiltrate data from the organization. This is how DNS tunneling works for CnC commands sent to a botnet:

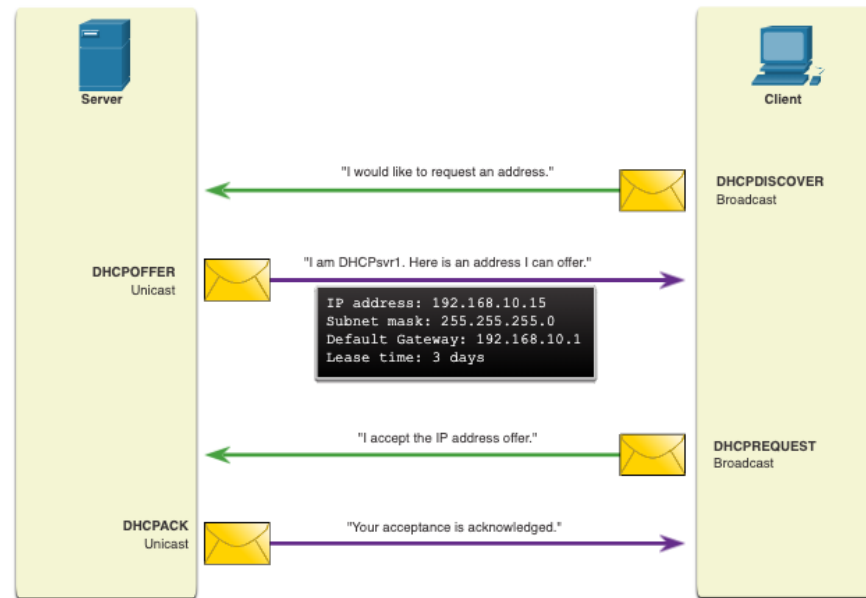
1. The command data is split into multiple encoded chunks.
2. Each chunk is placed into a lower level domain name label of the DNS query.
3. Because there is no response from the local or networked DNS for the query, the request is sent to the ISP's recursive DNS servers.
4. The recursive DNS service will forward the query to the threat actor's authoritative name server.
5. The process is repeated until all the queries containing the chunks of are sent.
6. When the threat actor's authoritative name server receives the DNS queries from the infected devices, it sends responses for each DNS query, which contain the encapsulated, encoded CnC commands.
7. The malware on the compromised host recombines the chunks and executes the commands hidden within the DNS record.

To stop DNS tunneling, the network administrator must use a filter that inspects DNS traffic. Pay close attention to DNS queries that are longer than average, or those that have a suspicious domain name..

DHCP (Dynamic Host Configuration Protocol)

DHCP servers dynamically provide IP configuration information to clients.

In the figure, a client broadcasts a DHCP discover message. The DHCP server responds with a unicast offer that includes addressing information the client can use. The client broadcasts a DHCP request to tell the server that the client accepts the offer. The server responds with a unicast acknowledgment accepting the request.



IP Services

DHCP Attacks

A **DHCP spoofing attack** occurs when a rogue DHCP server is connected to the network and provides false IP configuration parameters to legitimate clients.

A **rogue server** can provide a variety of misleading information:

- **Wrong default gateway** - Threat actor provides an invalid gateway, or the IP address of its host to create a MITM attack. This may go entirely undetected as the intruder intercepts the data flow through the network.
- **Wrong DNS server** - Threat actor provides an incorrect DNS server address pointing the user to a malicious website.
- **Wrong IP address** - Threat actor provides an invalid IP address, invalid default gateway IP address, or both. The threat actor then creates a DoS attack on the DHCP client.

DHCP Attacks (Cont.)

Assume a threat actor has successfully connected a **rogue DHCP server** to a switch port on the same subnet as the target clients. The goal of the rogue server is to provide clients with **false IP configuration information**.

The client broadcasts a DHCP Discover request looking for a response from a DHCP server. Both servers receive the message.

The legitimate and rogue DHCP servers each respond with valid IP configuration parameters. The client replies to the first offer received

The client received the rogue offer first. It broadcasts a DHCP request accepting the parameters from the rogue server. The legitimate and rogue server each receive the request.

Only the rogue server unicasts a reply to the client to acknowledge its request. The legitimate server stops communicating with the client because the request has already been acknowledged.

Lab – Explore DNS Traffic

In this lab, you will complete the following objectives:

- Capture DNS Traffic

- Explore DNS Query Traffic

- Explore DNS Response Traffic

3.9 Network Security Best Practices

Confidentiality, Availability, and Integrity

Network security consists of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

Most organizations follow the CIA information security triad:

- **Confidentiality** - Only authorized individuals, entities, or processes can access sensitive information. It may require using cryptographic encryption algorithms such as AES to encrypt and decrypt data.
- **Integrity** - Refers to protecting data from unauthorized alteration. It requires the use of cryptographic hashing algorithms such as SHA.
- **Availability** - Authorized users must have uninterrupted access to important resources and data. It requires implementing redundant services, gateways, and links.

The Defense-in-Depth Approach

To ensure secure communications across both public and private networks, you must secure devices including routers, switches, servers, and hosts. Most organizations employ a defense-in-depth approach to security. It requires a combination of networking devices and services working together.

1. Several security devices and services are implemented.

- **VPN**
- **ASA Firewall**
- **IPS**
- **ESA/WSA**
- **AAA Server**

2. All network devices including the router and switches are hardened, which means that they have been secured to prevent threat actors from gaining access and tampering with the devices.

3. You must also secure data as it travels across various links. This may include internal traffic, but it is more important to protect the data that travels outside of the organization to branch sites, telecommuter sites, and partner sites.

Network Security Best Practices

Firewalls

A firewall is a system, or group of systems, that enforces an access control policy between networks.

Allow traffic from any external address to the web server.

Allow traffic to FTP server.

Allow traffic to SMTP server.

Allow traffic to internal IMAP server.

Deny all inbound traffic with network addresses matching internal-registered IP addresses.

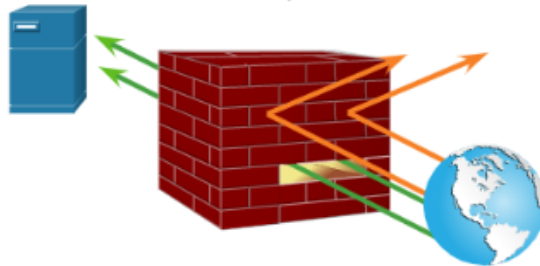
Deny all inbound traffic to server from external addresses.

Deny all inbound ICMP echo request traffic.

Deny all inbound MS Active Directory queries.

Deny all inbound traffic to MS SQL server queries.

Deny all MS Domain Local Broadcasts.



To defend against fast-moving and evolving attacks, you may need cost-effective detection and prevention systems integrated into the entry and exit points of the network.

IDS and IPS technologies share several characteristics. IDS and IPS technologies are both deployed as sensors. An IDS or IPS sensor can be in the form of several different devices:

- A router configured with Cisco IOS IPS software
- A device specifically designed to provide dedicated IDS or IPS services
- A network module installed in an adaptive security appliance (ASA), switch, or router
- IDS and IPS technologies detect patterns in network traffic using signatures, which is a set of rules that used to detect malicious activity. IDS and IPS technologies can detect atomic signature patterns (single-packet) or composite signature patterns (multi-packet).

Network Security Best Practices

IPS (Cont.)

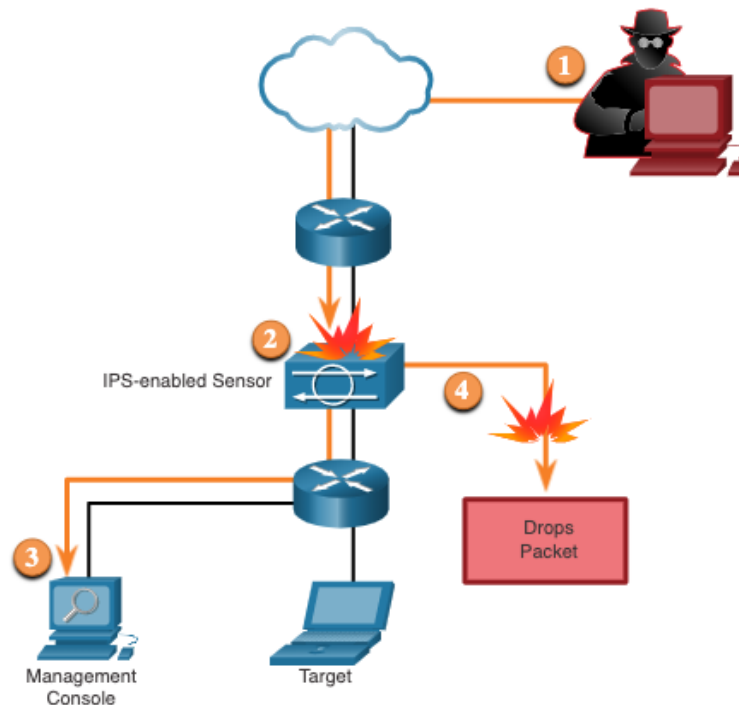
The figure shows how an IPS handles denied traffic.

The threat actor sends a packet destined for the target laptop.

The IPS intercepts the traffic and evaluates it against known threats and the configured policies.

The IPS sends a log message to the management console.

The IPS drops the packet.



Network Security Best Practices

Content Security Devices

The **Cisco Email Security Appliance (ESA)** is a special device designed to monitor Simple Mail Transfer Protocol (SMTP). The Cisco ESA is constantly updated by real-time feeds from the Cisco Talos. This threat intelligence data is pulled by the Cisco ESA every three to five minutes.

The **Cisco Web Security Appliance (WSA)** is a mitigation technology for web-based threats. The Cisco WSA combines advanced malware protection, application visibility and control, acceptable use policy controls, and reporting.

Cisco WSA provides complete control over how users access the internet. The WSA can perform blacklisting of URLs, URL-filtering, malware scanning, URL categorization, web application filtering, and encryption and decryption of web traffic.

